

APEXPLANET SOFTWARE PVT. LTD.

Cybersecurity & Ethical Hacking Internship

TASK 2 — OPENVAS VULNERABILITY ASSESSMENT REPORT

Metasploitable 2 — Vulnerability Scanning & Analysis

1. Objective

The objective of this activity was to perform a vulnerability assessment of the Metasploitable 2 target using OpenVAS/Greenbone Vulnerability Management. The assessment was conducted from Kali Linux against the intentionally vulnerable target in the isolated Host-Only laboratory environment. The scan was used to identify security weaknesses, classify findings by severity, review evidence for important vulnerabilities, and document suitable mitigation measures.

2. Lab Environment

Component	Configuration
Virtualization	Oracle VirtualBox
Attacker / Scanner	Kali Linux
Target	Metasploitable 2
Network Type	Host-Only Adapter
Kali IP	192.168.56.101
Target IP	192.168.56.102
Scanner	OpenVAS / Greenbone Vulnerability Management
OpenVAS Interface	Local web interface on Kali

3. Assessment Scope

The assessment was limited to the Metasploitable 2 virtual machine at 192.168.56.102 inside the controlled laboratory network. The purpose was vulnerability identification and analysis rather than testing any external or production system.

- Identify vulnerabilities exposed by the target services.
- Classify findings according to OpenVAS severity.
- Review high-impact findings and their detection evidence.
- Document practical remediation recommendations.
- Use the results as the vulnerability-assessment stage following Nmap service enumeration.

4. Scan Configuration and Methodology

The OpenVAS assessment was performed against the Metasploitable 2 target. The scan completed successfully and

produced a report containing 158 filtered results. The assessment methodology followed the sequence below.

Stage	Activity
1	Target identification and scan configuration
2	OpenVAS vulnerability scanning of 192.168.56.102
3	Service and vulnerability detection
4	Severity classification and result review
5	Detailed analysis of critical findings
6	Mitigation recommendations and reporting

5. OpenVAS Scan Summary

The completed OpenVAS report contained 158 results distributed across the severity classes shown below. The results page also showed the scan task as completed and the target as 192.168.56.102.

Severity Class	Number of Results
Critical	13
High	9
Medium	40
Low	6
Log / Informational	90
Total	158

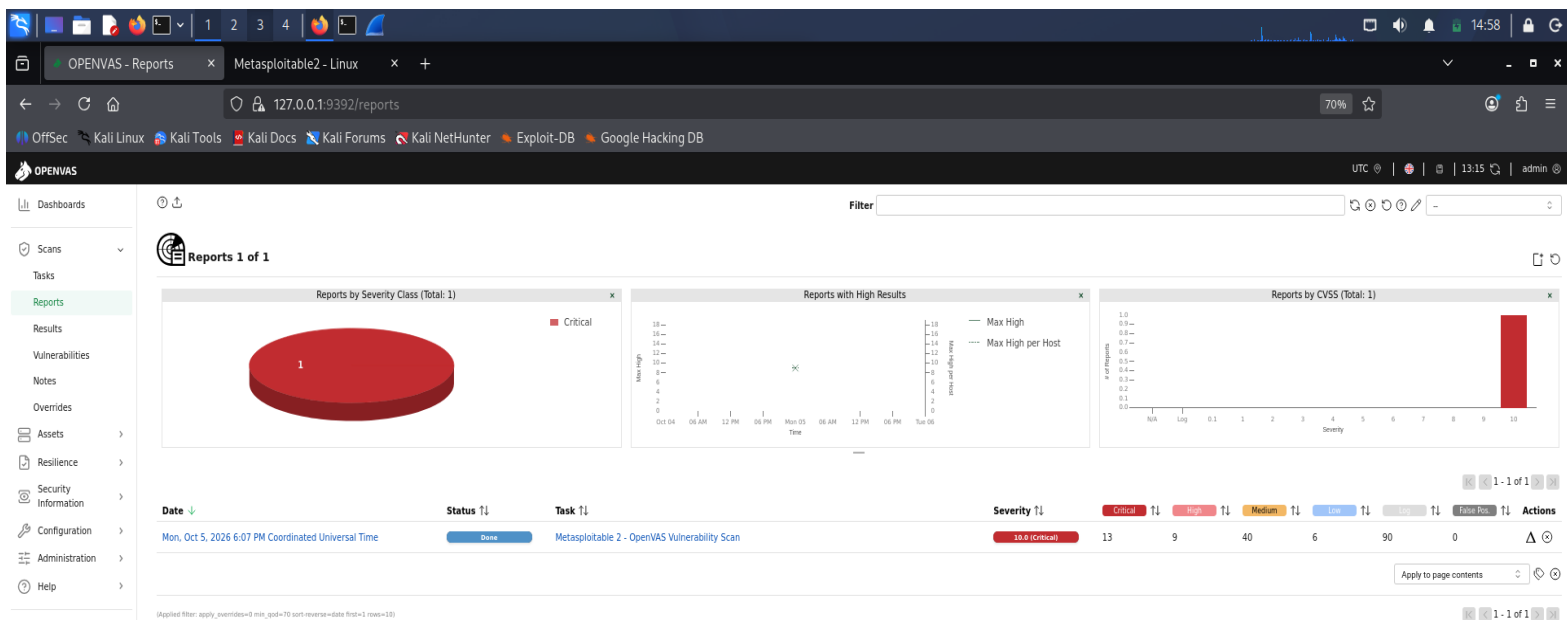


Figure 1: OpenVAS results summary and severity distribution

6. Scan Report Status

The OpenVAS Reports page showed one completed report for the task “Metasploitable 2 - OpenVAS Vulnerability Scan”. The report recorded 13 Critical, 9 High, 40 Medium, 6 Low and 90 Log results, with no false-positive results shown in the summary.

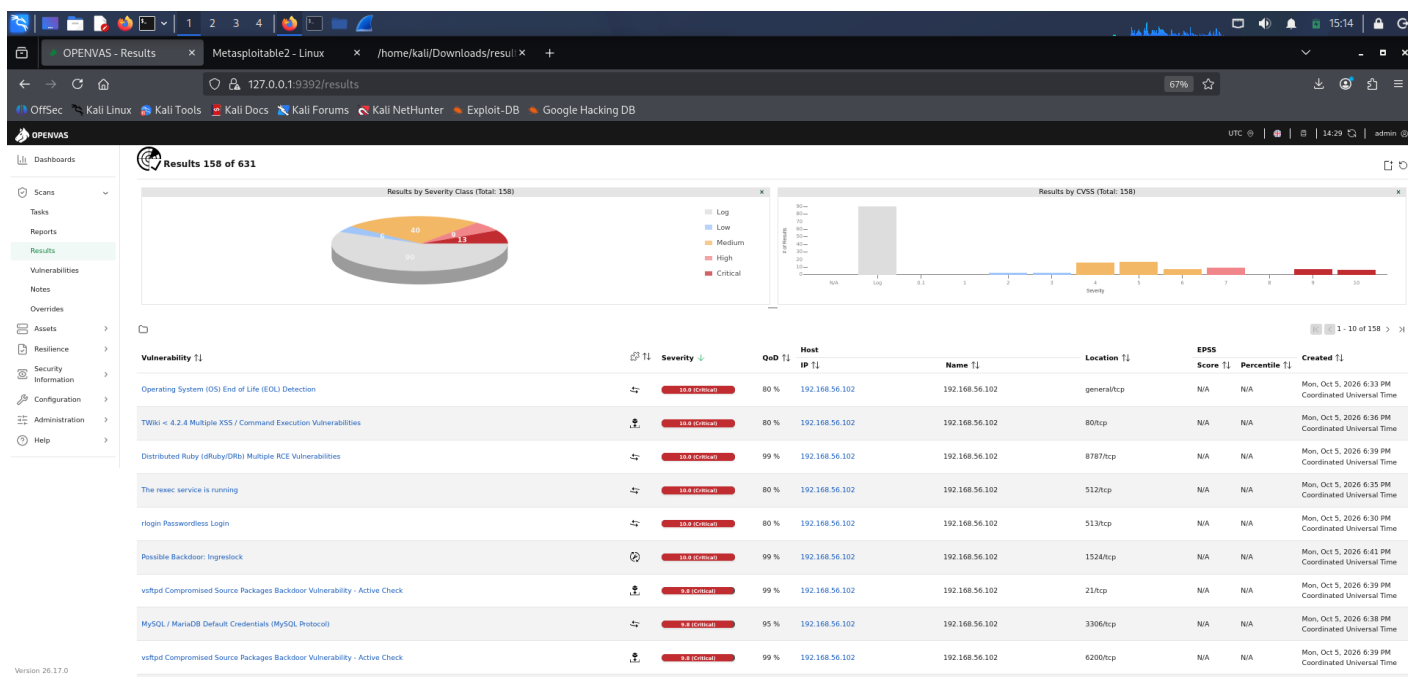


Figure 2: Completed OpenVAS report and severity counts

7. Major Critical Findings

The OpenVAS scan identified several critical findings on the target. The following findings are highlighted because they have a CVSS base score of 9.8 or 10.0 and/or indicate direct compromise, remote command execution, backdoors, or severe authentication weaknesses. OpenVAS detected an outdated TWiki installation below version **4.2.4** on the web service. The scanner reported multiple XSS and command-execution vulnerabilities caused by insufficient sanitization of TWiki variables. Successful exploitation could allow script or command execution and potentially compromise the affected application.

Finding	Severity / CVSS	Port / Location
Operating System (OS) End of Life (EOL) Detection	Critical / 10.0	general/tcp
TWiki < 4.2.4 Multiple XSS / Command Execution Vulnerabilities	Critical / 10.0	80/tcp
Distributed Ruby (dRuby/DRb) Multiple RCE Vulnerabilities	Critical / 10.0	8787/tcp
The rexec service is running	Critical / 10.0	512/tcp
rlogin Passwordless Login	Critical / 10.0	513/tcp
Possible Backdoor: Ingreslock	Critical / 10.0	1524/tcp
vsftpd Compromised Source Packages Backdoor Vulnerability	Critical / 9.8	21/tcp
MySQL / MariaDB Default Credentials	Critical / 9.8	3306/tcp

The uploaded OpenVAS XML also contains a second vsftpd backdoor result associated with port 6200/tcp, consistent with the scanner identifying the backdoor shell exposure.

8. Detailed Vulnerability Analysis

8.1 Operating System End of Life

OpenVAS identified the target operating system as Ubuntu Linux 8.04 and classified the operating-system end-of-life condition as Critical with a CVSS base score of 10.0. The scan records the EOL date as 2013-05-09. An unsupported operating system no longer receives normal vendor security updates, increasing exposure to known and unpatched vulnerabilities.

Mitigation: Upgrade the operating system to a supported release that continues to receive security updates.

8.2 TWiki Multiple XSS / Command Execution Vulnerabilities

OpenVAS identified TWiki below version 4.2.4 with multiple XSS and command-execution vulnerabilities. The scan indicates that insufficient sanitization of TWiki variables could allow script execution and Perl code execution. Successful exploitation could compromise the affected application.

Mitigation: Upgrade TWiki to version 4.2.4 or later and remove unsupported software versions.

8.3 Distributed Ruby (dRuby/DRb) Remote Code Execution

The dRuby/DRb service on port 8787/tcp was identified as vulnerable to remote command execution. OpenVAS reports that the service could allow unauthorized systems to submit Ruby commands or scripts when adequate access controls are absent.

Mitigation: Restrict access to trusted hosts, apply appropriate access controls, and configure the service securely.

Unnecessary exposure of the service should be removed.

8.4 rexec and rlogin Services

OpenVAS detected rexec on port 512/tcp and rlogin passwordless access on port 513/tcp. The scanner reports that rexec transmits username and password information without encryption and that the tested rlogin configuration allowed root access without a password.

Mitigation: Disable rexec and rlogin and use SSH for secure remote administration.

8.5 Possible Ingreslock Backdoor

The service on port 1524/tcp was identified as a possible backdoor. OpenVAS reports that an 'id;' command returned uid=0(root) gid=0(root), indicating root-level command execution through the service.

Mitigation: Remove the backdoor and perform a complete cleanup or rebuild of the affected system. Unnecessary exposed services should be disabled.

8.6 vsftpd 2.3.4 Backdoor

OpenVAS detected the known vsftpd 2.3.4 compromised-source-package backdoor vulnerability on port 21/tcp and also reported the associated backdoor exposure on port 6200/tcp. The finding has a CVSS score of 9.8. The scan identifies CVE-2011-2523 and states that the affected source package can open a shell on port 6200/tcp.

Mitigation: Replace the affected package with a trusted, repaired vendor package, validate package integrity/signatures, and remove unnecessary FTP exposure.

8.7 MySQL Default Credentials

OpenVAS identified default credentials on the MySQL service at port 3306/tcp. The detection result states that login as the root user with an empty password was possible. This creates a serious risk of unauthorized database access.

Mitigation: Change default credentials immediately, enforce strong authentication, and restrict database access to authorized hosts.

8.8 Apache Tomcat AJP RCE / Ghostcat

OpenVAS identified an Apache Tomcat AJP vulnerability on port 8009/tcp with a CVSS score of 9.8. The active check

demonstrated that the scanner could read /WEB-INF/web.xml through the AJP connector. The affected Tomcat versions are older than the fixed versions identified by the scan.

Mitigation: Upgrade Tomcat to a fixed supported version and restrict or disable the AJP connector when it is not required.

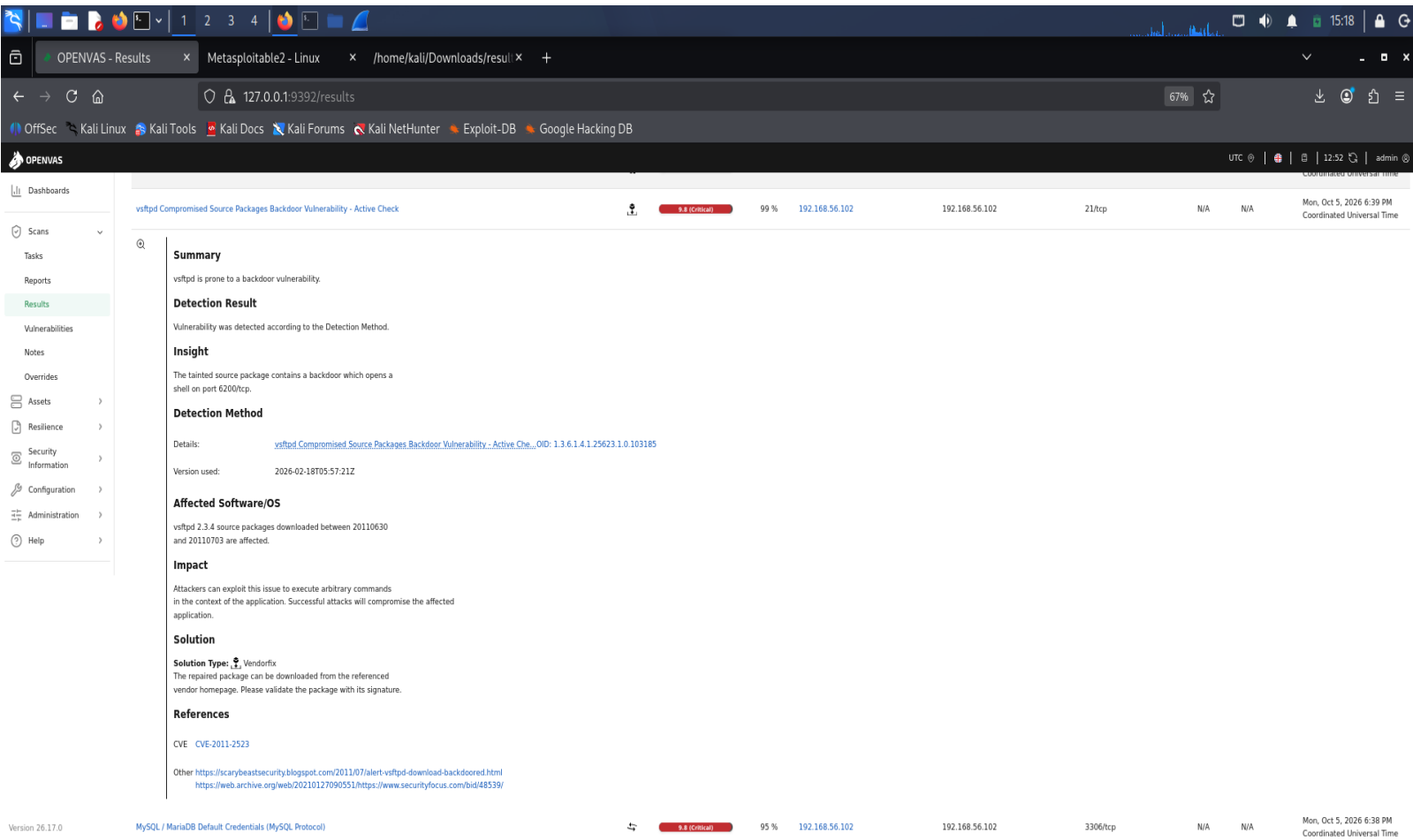


Figure 3: OpenVAS detailed evidence for the vsftpd backdoor vulnerability

9. Security Findings and Risk Assessment

Risk Area	Observation	Risk
Unsupported OS	Ubuntu 8.04 identified as EOL	Critical
Remote Code Execution	dRuby/DRb, TWiki and Tomcat findings	Critical
Backdoors	Ingreslock and vsftpd backdoor findings	Critical
Weak Remote Administration	rexec and passwordless rlogin	Critical
Weak Authentication	MySQL root login with empty password	Critical
Web Application Exposure	TWiki vulnerabilities on HTTP	Critical

10. Mitigation Recommendations

- Upgrade the end-of-life operating system to a supported release.
- Remove or update vulnerable applications and services.
- Disable unnecessary legacy services such as rexec and rlogin.
- Replace compromised vsftpd packages and validate package integrity.

- Remove suspected backdoors and rebuild compromised systems where appropriate.
- Change all default or empty passwords and enforce strong authentication.
- Upgrade vulnerable Apache Tomcat installations and restrict unnecessary AJP exposure.
- Restrict network access to services that do not need to be remotely reachable.
- Repeat vulnerability scanning after remediation to verify that critical findings have been reduced.

11. Results

Activity	Result
OpenVAS vulnerability scan	Successfully completed
Target	192.168.56.102
Total filtered results	158
Critical findings	13
High findings	9
Medium findings	40
Low findings	6
Log / Informational results	90
Major critical findings reviewed	OS EOL, TWiki, dRuby/DRb, rexec, rlogin, Ingreslock, vsftpd, MySQL, Tomcat

12. Security Observations

The OpenVAS assessment demonstrated that the Metasploitable 2 system has a very broad and severe attack surface. The results include unsupported software, insecure legacy remote-access services, default credentials, web application vulnerabilities, backdoors, and remote code execution conditions. The severity distribution is dominated by informational/log results numerically, but the presence of 13 Critical and 9 High findings indicates substantial security exposure.

The assessment also demonstrates the value of combining Nmap enumeration with vulnerability scanning. Nmap identifies exposed ports and software versions, while OpenVAS provides vulnerability-oriented analysis and remediation information.

13. Conclusion

The OpenVAS vulnerability assessment of Metasploitable 2 was successfully completed in the controlled laboratory environment. The scan produced 158 filtered results, including 13 Critical, 9 High, 40 Medium and 6 Low findings, along with 90 Log/Informational results. Critical issues included an end-of-life operating system, remote code execution vulnerabilities, legacy insecure services, backdoors, default database credentials, and the known vsftpd 2.3.4 backdoor.

The results provide a detailed vulnerability baseline for the target and identify clear remediation priorities. Updating unsupported software, removing vulnerable or unnecessary services, replacing compromised packages, strengthening authentication, and restricting network exposure are the primary corrective actions.